ISCTE – Instituto Universitário de Lisboa

Escola de Tecnologias e Arquitetura

SEGURANÇA DE REDES E SISTEMAS DE INFORMAÇÃO

Relatório do Projeto – Parte 1 (Teórica)

Middleware Adaptativo de Privacidade e Redução de Dados em Sistemas de Informação

Implementação de um Modelo Inspirado em PADRES/PRIPRO para Proteção de Dados e Segurança

---

Elaborado por:

João Barradas 146757
Lucas Martins 149104
Malam Sanhá 125754
Marta Gaspar 104994

Docente

Daniel Maximino Caçador

Lisboa, 1 de novembro de 2026

Resumo

A integração entre sistemas de informação através de APIs REST faz circular respostas que contêm frequentemente mais dados pessoais do que os necessários para cada destinatário. Os mecanismos de autorização tradicionais decidem se um pedido pode aceder a um recurso, mas não adaptam o conteúdo devolvido. Este relatório apresenta a fundamentação teórica de um middleware/proxy de privacidade em Python que, colocado entre os clientes e os serviços de backend, identifica o perfil associado a cada pedido e transforma a resposta antes de a entregar. Inspirada nos modelos PRIPRO e PADRES, a proposta define três perfis (Administrador, Operacional/Analista e Público/Terceiros) e aplica, consoante o perfil, ações de omissão, mascaragem, pseudonimização e agregação de atributos. O trabalho enquadra a proposta no RGPD e na Diretiva NIS2, compara-a com abordagens relacionadas, formaliza métricas para a informação exposta (Entropia de Shannon) e para a redução do payload (ΔD), e descreve a arquitetura e o plano de avaliação do protótipo a desenvolver na Parte 2.

Palavras-chave: PRIPRO/PRIADA, PADRES, Gestão de Utilizadores, Minimização de Dados, NIS2.

Glossário

API - Interface de Programação de Aplicações.

Ubíquo - Que está presente ou pode ser acedido em qualquer lugar, através de diferentes dispositivos e ambientes.

PRIPRO - Privacy Profiles: perfis de privacidade que definem as preferências e os requisitos de privacidade dos utilizadores.

PRIADA - Privacy Adaptation: adaptação das respostas ou dos dados disponibilizados de acordo com os requisitos e perfis de privacidade.

minTAP - Practical Data Access Minimization in Trigger-Action Platforms: abordagem para minimizar o acesso a dados pessoais em plataformas baseadas em relações de gatilho-ação.

Índice

Resumo i

Capítulo 1. Introdução 1
1.1. Contexto e Motivação 1
1.2. Definição do Problema 2
1.3. Objetivos do Trabalho 2

Capítulo 2. Enquadramento Regulatório e Normativo 3
2.1. Regulamento Geral sobre a Proteção de Dados (RGPD) 3
2.2. Diretiva NIS2 4
2.3. Implicações para o protótipo 4

Capítulo 3. Estado da Arte e Trabalhos Relacionados 7
3.1. Modelos Base 7
3.2. Análise dos Modelos 7
3.2.1. Modelo PRIPRO / PRIADA 7
3.2.2. Modelo PADRES 8
3.3. Análise Comparativa dos Trabalhos Relacionados 8
3.3.1. Trabalhos Relacionados 8
3.3.2. Resumo da análise comparativa 9
3.4. Tabela Comparativa dos Trabalhos Relacionados 9

Capítulo 4. Formalização Matemática 11
4.1. Nível de Informação: Entropia de Shannon 11
4.2. Aplicação no Middleware 11
4.3. Taxa de Redução de Payload (ΔD) 11
4.4. Definição Formal: 12
4.5. Dinâmica Adaptativa: 12
4.6. Função de Utilidade e Tomada de Decisão Adaptativa 12

Capítulo 5. Arquitetura Proposta para o Middleware 13
5.1. Componentes 13
5.2. Fluxo de Processamento de um Pedido 14
5.3. Perfis de Acesso e Políticas de Transformação 14
5.4. Considerações de Segurança 15
5.5. Tecnologias e Plano de Avaliação 15

Capítulo 6. Conclusões e Trabalhos Futuros 17

Referências Bibliográficas 19

CAPíTULO 1

Introdução

A crescente integração entre sistemas de informação tem aumentado a circulação de dados através de interfaces de programação de aplicações (APIs), em particular de serviços HTTP/REST. Embora esta partilha permita automatizar processos e disponibilizar informação a diferentes entidades, uma resposta pode conter atributos que não são necessários para todos os seus destinatários. A exposição desses atributos aumenta o risco para a privacidade e pode também implicar a transmissão de um volume de dados superior ao necessário.

Neste contexto, este trabalho propõe o desenvolvimento de um middleware/proxy de privacidade em Python, colocado entre os clientes e os serviços de backend. A camada intermédia deverá identificar o perfil associado ao pedido e adaptar a resposta antes de a devolver ao cliente. Deste modo, pretende-se aproximar o controlo de acesso da própria representação dos dados transmitidos, sem pressupor que todos os clientes autorizados necessitam da mesma informação.

1.1. Contexto e Motivação

Em ecossistemas de APIs RESTful, os mecanismos de autorização determinam frequentemente se um pedido pode aceder a um recurso, mas não adaptam necessariamente o conteúdo da resposta às necessidades concretas de quem o solicita. Assim, um consumidor autorizado a consultar um recurso pode receber dados pessoais identificáveis (PII) ou outros atributos sensíveis, mesmo quando apenas necessita de uma visão parcial ou de métricas consolidadas. A aplicação de uma política uniforme pode, por isso, favorecer a utilidade operacional à custa da minimização da informação divulgada.

A motivação do projeto é explorar uma abordagem intermédia que combine perfis de acesso com transformações do payload. Inspirado nos modelos PRIPRO/PRIADA, que orientam a gestão dinâmica de perfis de privacidade e a gestão de contexto em ambientes distribuídos [**1**], e PADRES, associado à redução de dados consciente da privacidade e à regulação de segurança [**2**], o middleware deverá adaptar a resposta a três perfis previstos na proposta: o Administrador recebe os dados necessários às suas funções e permissões; o Operacional/Analista recebe dados com mascaragem ou pseudonimização de atributos confidenciais; e o Público/Terceiros recebe informação agregada e reduzida. A aplicação destas transformações procura limitar a exposição de dados e, nos casos em que os campos são omitidos ou agregados, reduzir também o payload transmitido.

Esta abordagem exige considerar simultaneamente a proteção da informação e a sua utilidade. A transformação não deve remover dados necessários à finalidade legítima do

pedido, e a redução do payload não constitui, por si só, uma garantia de anonimização ou de conformidade regulatória. Por esse motivo, o trabalho enquadra a proposta nos princípios do RGPD e na resiliência dos sistemas de informação abordada pela Diretiva NIS2, e prevê avaliar o comportamento do protótipo através de testes funcionais e métricas de desempenho.

1.2. Definição do Problema

O problema central consiste na dificuldade de conciliar a disponibilização de informação útil com a limitação dos dados pessoais e do volume de informação transmitidos a cada consumidor. Uma decisão estática de permitir ou negar o acesso, incluindo uma política baseada em papéis (RBAC), pode não distinguir entre destinatários com necessidades diferentes perante o mesmo recurso. Como consequência, mesmo quando o acesso é legítimo, a resposta pode conter mais informação do que a necessária.

Pretende-se, por isso, estudar como um middleware pode usar o perfil associado ao pedido para aplicar políticas de transformação coerentes antes de encaminhar a resposta. A solução deverá articular a identificação do perfil, a seleção dos campos a manter ou transformar e a entrega da resposta adaptada. A sua avaliação deverá verificar se cada perfil recebe o tipo de informação esperado e medir o custo introduzido pela camada intermédia, incluindo latência e consumo de recursos, bem como a variação do tamanho do payload. O desafio está em reduzir a exposição e a transmissão de dados sem comprometer a correção funcional das respostas.

1.3. Objetivos do Trabalho

O objetivo geral é conceber e avaliar um protótipo de middleware/proxy que adapte respostas de APIs segundo perfis de acesso, combinando proteção da privacidade e redução de dados. Para o concretizar, o projeto divide-se em duas componentes:

- **Objetivo Teórico (Parte 1):** Rever abordagens de controlo de acesso adaptativo e de proteção da privacidade, enquadrar a proposta face ao RGPD e à Diretiva NIS2 e formalizar métricas para discutir a informação exposta, com base na Entropia de Shannon, e a redução do payload, através de ΔD.
- **Objetivo Prático (Parte 2):** Implementar um protótipo modular em Python, recorrendo a FastAPI ou Flask, que intercepte pedidos HTTP/REST e adapte as respostas para os perfis definidos. Validar funcionalmente as transformações e comparar o comportamento com e sem middleware, medindo a latência, o consumo de CPU e memória e o tamanho dos dados transmitidos.

O trabalho incide sobre um protótipo e a sua avaliação experimental; os resultados permitirão caracterizar a abordagem no cenário de teste, não constituindo por si só uma certificação de conformidade nem uma demonstração de adequação a ambientes de produção.

CAPíTULO 2

Enquadramento Regulatório e Normativo

A conceção de um middleware que intermedeia pedidos e respostas deve considerar tanto a proteção dos dados pessoais como a segurança e a resiliência dos sistemas de informação. Neste projeto, o Regulamento Geral sobre a Proteção de Dados (RGPD) é relevante quando os dados tratados permitem identificar diretamente ou indiretamente uma pessoa singular. A Diretiva NIS2, por sua vez, estabelece requisitos de gestão de riscos de cibersegurança para as entidades abrangidas pelo seu âmbito. Os dois instrumentos são complementares, mas têm objetivos e âmbitos de aplicação distintos: a existência do protótipo, por si só, não demonstra conformidade com nenhum deles.

2.1. Regulamento Geral sobre a Proteção de Dados (RGPD)

O RGPD estabelece princípios e obrigações aplicáveis ao tratamento de dados pessoais [**3**]. Para o middleware proposto, são particularmente relevantes:

- **Limitação das finalidades e minimização (Artigo 5.º, n.º 1, alíneas b) e c)):** Os dados devem ser tratados para finalidades determinadas e explícitas, e limitar-se ao que é necessário para essas finalidades. No protótipo, isto implica definir, por recurso e perfil, que campos são necessários, em vez de devolver automaticamente toda a resposta do serviço de backend.
- **Exatidão e limitação da conservação (Artigo 5.º, n.º 1, alíneas d) e e)):** Os dados devem ser exatos e conservados apenas durante o período necessário. Embora o middleware se concentre na resposta em trânsito, os registos e dados temporários que possa produzir também devem ser considerados na conceção e nos testes.
- **Integridade, confidencialidade e responsabilidade (Artigo 5.º, n.º 1, alínea f), e n.º 2):** O responsável pelo tratamento deve assegurar proteção adequada contra tratamento não autorizado ou ilícito e conseguir demonstrar o cumprimento dos princípios aplicáveis. A adaptação de respostas deve, portanto, ser acompanhada por controlos de acesso e por políticas verificáveis, não apenas por remoção de campos.
- **Proteção de dados desde a conceção e por defeito (Artigo 25.º):** As medidas técnicas e organizacionais devem ser integradas na conceção do tratamento e, por defeito, limitar a quantidade de dados, a extensão do tratamento, o período de conservação e a acessibilidade. A separação das respostas por perfil constitui uma possível medida técnica, desde que os perfis e as regras sejam definidos de forma adequada à finalidade.

- **Segurança do tratamento (Artigo 32.º):** As medidas devem ser adequadas ao risco e podem incluir pseudonimização e cifragem, mecanismos para garantir confidencialidade, integridade, disponibilidade e resiliência, bem como processos de teste e avaliação regulares. O artigo não prescreve uma tecnologia única: a escolha deve considerar o contexto, os riscos e o estado da técnica.

É importante distinguir as transformações previstas. A *mascaragem* pode ocultar parte de um valor numa resposta, mas não garante, por si só, que a pessoa deixe de ser identificável. A *pseudonimização*, nos termos do artigo 4.º, n.º 5, substitui identificadores por outros valores e exige que a informação adicional que permita atribuir os dados a uma pessoa seja mantida separadamente e protegida; os dados pseudonimizados continuam a ser dados pessoais quando a reidentificação é possível. A anonimização exige que a identificação deixe efetivamente de ser razoavelmente possível, o que depende também do contexto e de outros dados disponíveis. Assim, reduzir o tamanho do payload ou aplicar hashing não deve ser apresentado automaticamente como anonimização.

2.2. Diretiva NIS2

A Diretiva (UE) 2022/2555, conhecida como NIS2, procura estabelecer um nível elevado comum de cibersegurança na União Europeia [4]. A sua aplicação depende do âmbito definido na Diretiva e da legislação nacional que a transpõe; não se deve, por isso, assumir que qualquer serviço ou protótipo está automaticamente sujeito às mesmas obrigações. Para as entidades abrangidas, a Diretiva prevê responsabilidades de governação e medidas de gestão de riscos, tendo em conta a exposição a riscos, a dimensão da entidade e a probabilidade e gravidade dos incidentes.
O artigo 21.º identifica áreas de medidas de gestão de riscos, entre as quais o tratamento de incidentes, a continuidade das atividades, a segurança da cadeia de fornecimento, a segurança na aquisição, desenvolvimento e manutenção de sistemas, a avaliação da eficácia das medidas, políticas de criptografia, controlo de acessos e, quando adequado, autenticação multifator e comunicações seguras. A Diretiva não se reduz à proteção de dados pessoais: o seu foco inclui a disponibilidade e a resiliência dos sistemas e serviços.
No contexto do projeto, um middleware que recebe e reencaminha pedidos é também um componente cuja configuração e funcionamento devem ser considerados no modelo de ameaças. Uma política de filtragem pode reduzir a exposição de campos, mas não substitui medidas como autenticação robusta, validação dos tokens, proteção do tráfego, gestão segura de segredos, atualização de dependências, tratamento controlado de erros e preparação para falhas. A relevância e a proporcionalidade de cada medida devem ser avaliadas em função do cenário de utilização.

2.3. Implicações para o protótipo

O enquadramento regulatório traduz-se em requisitos de conceção e de validação, não numa declaração de conformidade:

- **Autorização antes da transformação:** o perfil deve ser obtido de uma credencial validada, e não aceite como um valor arbitrário fornecido pelo cliente. Pedidos sem autenticação ou autorização válida não devem receber dados do backend.
- **Políticas explícitas por perfil:** cada política deve indicar os campos permitidos, mascarados, pseudonimizados, omitidos ou agregados, de acordo com a finalidade prevista. A configuração deve seguir o princípio do menor privilégio e evitar que campos novos sejam expostos implicitamente.
- **Proteção do fluxo e dos componentes:** devem ser consideradas a proteção das comunicações, a gestão de credenciais e segredos, a validação de entradas e respostas e a divulgação mínima de informação em erros e registos.
- **Verificação funcional e de segurança:** os testes devem confirmar que cada perfil recebe apenas a resposta prevista, que pedidos inválidos ou não autorizados são rejeitados e que as transformações não alteram indevidamente os dados necessários à finalidade do serviço.
- **Avaliação do impacto:** além de verificar as respostas por perfil, a avaliação prática deverá medir a latência, o consumo de CPU e memória e o tamanho do payload antes e depois da transformação. Estas métricas caracterizam o protótipo, mas não medem, isoladamente, o cumprimento das obrigações legais.

Deste modo, o RGPD orienta sobretudo a necessidade e a forma do tratamento de dados pessoais, enquanto a NIS2 enquadra a gestão de riscos de cibersegurança e a resiliência das entidades abrangidas. A arquitetura proposta pode contribuir para objetivos relacionados com ambos, mas a avaliação de conformidade exigiria analisar o tratamento completo, os responsáveis envolvidos, o contexto operacional e as medidas organizacionais e técnicas aplicáveis.

CAPíTULO 3

Estado da Arte e Trabalhos Relacionados

3.1. Modelos Base

A proposta deste projeto baseia-se na fusão e adaptação dos seguintes modelos de referência:

- Modelo PRIPRO / PRIADA
- Modelo PADRES

3.2. Análise dos Modelos

3.2.1. Modelo PRIPRO / PRIADA

O modelo PRIPRO (*PRIvacy PROfiles*) integra a arquitetura UbiPri (*Ubiquitous Privacy*), desenvolvida para a gestão e controlo da privacidade em ambientes ubíquos. Esta arquitetura encontra-se organizada em módulos independentes, responsáveis por diferentes dimensões da gestão da privacidade [**5, 1, 6**].

No contexto desta arquitetura, o módulo PRIPRO é responsável pela gestão dos perfis dos utilizadores, permitindo associar diferentes permissões e restrições aos recursos e serviços disponíveis. O objetivo é garantir que o acesso à informação e aos recursos do ambiente respeita as preferências e condições estabelecidas para cada perfil.

Uma das características relevantes do PRIPRO é a possibilidade de evolução dinâmica dos perfis. A abordagem considera a frequência com que um utilizador interage com determinado ambiente para gerir a progressão ou regressão do seu perfil. Esta evolução é suportada por uma taxonomia de métricas, parâmetros e critérios hierárquicos, permitindo adaptar as permissões às características da interação [**1**].

Complementarmente, o módulo PRIADA (*PRIvacy ADAptation*) assume a responsabilidade pela gestão e controlo da adaptação, tratando informação relacionada com a adaptação de software e hardware no ambiente ubíquo. Enquanto o PRIPRO se concentra na gestão dos perfis e das respetivas permissões, o PRIADA está associado à adaptação do comportamento do sistema em função das condições identificadas. [**6, 1, 7**].

O PRIADA foca-se na gestão e adaptação da informação considerando a localização e o contexto da interação entre o indivíduo e o ambiente. O modelo procura determinar as condições de acesso à informação com base nas circunstâncias em que ocorre a interação, evidenciando a importância de considerar o contexto como uma variável na aplicação das políticas de privacidade [**7**].

3.2.2. Modelo PADRES

O PADRES (*Tool for PrivAcy, Data REgulation and Security*), desenvolvido por Pereira, Crocker e Leithardt (2022), é uma ferramenta de código aberto concebida para apoiar a análise da privacidade e segurança de aplicações Web, tendo como principal enquadramento os requisitos do Regulamento Geral sobre a Proteção de Dados (RGPD). A sua motivação está relacionada com a complexidade do processo de avaliação da conformidade regulamentar, que exige a análise de procedimentos organizacionais, aplicações e infraestruturas tecnológicas [**2**].

A ferramenta organiza os principais princípios do RGPD sob a forma de listas de verificação e questionários, cujas respostas são introduzidas manualmente pelo utilizador. Esta abordagem permite sistematizar a avaliação de diferentes aspetos relacionados com o tratamento de dados pessoais, facilitando a identificação de possíveis lacunas relativamente aos requisitos regulamentares. Assim, o PADRES funciona como um instrumento de apoio à análise e à auditoria regulamentar [**2**].

Para complementar a componente regulamentar, o PADRES integra ferramentas externas de análise de segurança, nomeadamente o Nmap, o OWASP ZAP e analisadores de cookies. Os resultados obtidos através destas ferramentas são armazenados e posteriormente combinados com as respostas dos questionários, permitindo gerar um relatório consolidado com sugestões e recomendações. Esta integração procura reunir, num único processo, informação relativa à avaliação da privacidade e à identificação de potenciais vulnerabilidades de segurança nas aplicações analisadas [**2**].

3.3. Análise Comparativa dos Trabalhos Relacionados

3.3.1. Trabalhos Relacionados

Os trabalhos analisados abordam diferentes dimensões da proteção da privacidade, desde a gestão dos perfis dos utilizadores até à avaliação da conformidade regulamentar das aplicações. O PRIPRO e o PRIADA concentram-se na gestão e adaptação das políticas de privacidade em função dos perfis e do contexto, enquanto o PADRES procura apoiar a identificação de aspetos relacionados com a privacidade e a segurança de aplicações Web. Apesar de partilharem a preocupação com a proteção da informação, os seus objetivos e mecanismos de implementação são distintos [**1, 7, 2**].

Uma abordagem mais diretamente relacionada com a minimização de dados em interfaces de programação é apresentada por Pallas et al. (2022), através da solução Janus. Este trabalho aborda o problema da disponibilização de informação excessiva por APIs Web, propondo um mecanismo configurável de minimização de dados para APIs GraphQL. A solução permite definir diferentes operações de redução de informação de acordo com os papéis dos consumidores, procurando disponibilizar apenas os atributos necessários a cada pedido. Os autores apresentam ainda uma implementação experimental e uma avaliação do desempenho, demonstrando a viabilidade da aplicação de políticas de minimização diretamente nas interfaces de acesso aos dados [**8**].

Outra contribuição relevante é apresentada por Chen et al. (2022), através do sistema minTAP (*Practical Data Access Minimization in Trigger-Action Platforms*). Esta abordagem procura reduzir o acesso excessivo a dados pessoais em plataformas que permitem estabelecer regras de automação entre diferentes serviços. Os autores identificam dois tipos de acesso excessivo: ao nível dos atributos, quando uma aplicação recebe mais campos do que aqueles de que necessita, e ao nível dos serviços, quando lhe são disponibilizadas mais APIs do que as necessárias. Para responder a este problema, o minTAP procura identificar os dados estritamente necessários à execução de cada regra, limitando a informação disponibilizada às aplicações consumidoras [**9**].

A análise conjunta destes trabalhos permite identificar duas dimensões complementares. Por um lado, os modelos PRIPRO e PRIADA demonstram a importância de utilizar perfis e informação contextual para determinar as condições de acesso e adaptação. Por outro, as abordagens Janus e minTAP demonstram a possibilidade de aplicar a minimização ao nível dos atributos disponibilizados às aplicações consumidoras. O PADRES acrescenta uma perspetiva de avaliação regulamentar e de segurança, permitindo enquadrar a necessidade de verificar os mecanismos de proteção implementados [**1, 7, 2, 8, 9**].

3.3.2. Resumo da análise comparativa

Apesar da existência destas abordagens, a proposta deste projeto procura reunir estas dimensões numa camada intermédia dedicada à adaptação de respostas HTTP/REST. Ao contrário de uma solução centrada exclusivamente na gestão de permissões, pretende-se que o middleware utilize o perfil associado ao pedido para determinar não só se o acesso é permitido, mas também que informação pode ser devolvida. A transformação poderá envolver a seleção de campos, a mascaragem ou pseudonimização de atributos e a agregação de informação, de acordo com as políticas definidas para cada perfil.

Deste modo, pretende-se explorar uma arquitetura que combine a gestão de perfis inspirada no PRIPRO/PRIADA com os princípios de minimização de dados presentes em trabalhos como Janus e minTAP, mantendo o enquadramento regulamentar e de segurança associado ao PADRES. A avaliação experimental permitirá analisar a eficácia funcional das transformações e o respetivo impacto na latência, no consumo de recursos e no volume de dados transmitidos. Esta combinação constitui a principal diferenciação da abordagem proposta relativamente aos trabalhos analisados.

3.4. Tabela Comparativa dos Trabalhos Relacionados

A Tabela 3.1 apresenta uma comparação dos trabalhos analisados na secção anterior, considerando os seus objetivos, mecanismos de proteção, utilização de perfis, adaptação da informação e aplicabilidade ao contexto das APIs. A comparação permite identificar as características já exploradas na literatura e as funcionalidades que se pretende reunir no middleware proposto.

Neste enquadramento, o middleware proposto procura integrar a gestão de perfis com a transformação direta das respostas de APIs REST, permitindo aplicar diferentes níveis

de proteção aos mesmos recursos. A sua avaliação experimental permitirá verificar se esta integração consegue reduzir a quantidade de informação transmitida e a exposição de atributos sensíveis, mantendo a utilidade funcional das respostas e introduzindo um custo computacional aceitável.

TABELA 3.1. Comparação dos modelos e trabalhos relacionados

Modelo / Abordagem	**Controlo de Acesso**	**Mascaragem**	**Redução (ΔD)**	**Adaptabilidade**	**Minimização de Dados**	**Âmbito de Aplicação**
PRIPRO / PRIADA	Perfis e contexto	Não especificado	Não especificado	Dinâmica	Não especificada	Ambientes ubíquos
PADRES	Não aplicável	Não	Não	Avaliação e recomendações	Não implementada	Aplicações Web
Janus	Baseado em papéis	Não especificado	Sim	Configurável	Seleção de atributos	APIs GraphQL
minTAP	Dados e serviços	Não especificado	Sim	Dependente das regras	Atributos e serviços	Plataformas Trigger-Action
Proposta (Middleware)	**Contextual / Perfis**	**Sim**	**Sim**	**Dinâmica**	**Seleção, mascaragem e agregação**	**APIs: HTTP e REST**

CAPíTULO 4

Formalização Matemática

Esta secção estabelece o rigor matemático necessário para modelar, quantificar e otimizar o comportamento de um middleware de privacidade, garantindo a conformidade com os princípios de minimização de dados e proteção rigorosa da informação. Para avaliar de forma rigorosa o impacto do middleware tanto ao nível da privacidade como ao nível da eficiência da rede, são utilizadas duas métricas matemáticas fundamentais.

4.1. Nível de Informação: Entropia de Shannon

A Entropia de Shannon $H(X)$ mede a incerteza ou o grau de informação contido numa variável aleatória de dados X com possíveis resultados $\{x_1, x_2, \ldots, x_n\}$ e probabilidades $P(x_i)$ **[10]**:

$$H(X) = -\sum_{i=1}^{n} P(x_i) \log_2 P(x_i) \tag{4.1}$$

Quando o middleware aplica técnicas de mascaragem dinâmica, pseudonimização ou eliminação de campos sensíveis para os perfis de menor privilégio (ex.: Analista ou Público), a variabilidade e incerteza associadas aos dados revelados altera-se, permitindo quantificar formalmente a redução de informação exposta.

4.2. Aplicação no Middleware

A entropia quantifica a quantidade de informação útil ou a surpresa associada aos dados antes e depois da intervenção do middleware. Valores elevados de entropia indicam maior dispersão ou imprevisibilidade dos dados (maior riqueza informativa, mas também maior risco de exposição de dados não estruturados). O middleware adaptativo utiliza limiares de entropia para decidir dinamicamente quando aplicar técnicas de anonimização, pseudonimização ou supressão, reduzindo o valor informático de campos sensíveis para salvaguardar a privacidade do titular sem comprometer a integridade operacional do sistema.

4.3. Taxa de Redução de Payload (ΔD)

A taxa de redução do tamanho dos dados transmitidos na rede (ΔD) quantifica a eficiência do esquema tipo PADRES em termos de poupança de largura de banda. Sejam S_{orig} o tamanho do payload original em bytes e S_{trans} o tamanho do payload transformado entregue ao cliente:

4.4. Definição Formal:

Considere-se o tamanho original do payload de dados em bits ou bytes antes do processamento como S_{orig} e o tamanho do payload resultante após a aplicação das políticas de filtragem, truncagem ou anonimização pelo middleware como S_{trans} . A taxa de redução de payload (ΔD) é expressa percentualmente por:

$$\Delta D = \left(1 - \frac{S_{trans}}{S_{orig}}\right) \times 100\% \tag{4.2}$$

4.5. Dinâmica Adaptativa:

O parâmetro (ΔD não é estático; ele adapta-se com base no contexto de segurança, no nível de confiança do recetor, na criticidade dos dados e no estado de ameaça detetado pelo sistema. Um nível de risco mais elevado aciona políticas mais restritivas no middleware, maximizando (ΔD através da eliminação de metadados redundantes ou campos identificadores secundários. Esta métrica serve como indicador de desempenho essencial para comprovar a eficiência do sistema perante requisitos regulatórios e de otimização de largura de banda.

4.6. Função de Utilidade e Tomada de Decisão Adaptativa

O middleware não se limita a aplicar transformações estáticas; ele ajusta o seu comportamento em tempo real com base no contexto de risco e nos requisitos operacionais.

- **Modelação do Contexto de Risco :** uma função que avalia o nível de ameaça ou a sensibilidade do contexto de transmissão num dado momento t, agregando fatores como a localização da rede, o perfil do utilizador e a classificação da informação.
- **Otimização do Equilíbrio (Trade-off) entre Privacidade e Utilidade:** objetivo do middleware é maximizar a privacidade do utilizador (através da redução de entropia e maximização de (ΔD) mantendo uma utilidade aceitável dos dados . Isto pode ser formulado como um problema de otimização restrita:

$$\max \mathcal{P}(\Delta D, H(X)) \quad \text{sujeito a} \quad U \geq U_{\min} \tag{4.3}$$

Onde P representa o ganho de privacidade e U é o limiar mínimo de utilidade necessário para que o sistema de informação recetor execute as suas funções sem falhas operacionais.

- **Mecanismo de Decisão Dinâmica:** Quando R(t) ultrapassa um determinado patamar crítico, o middleware reduz o peso da utilidade e intensifica as políticas de anonimização e supressão de atributos. Quando o ambiente é seguro e confiável, o sistema reduz o impacto da transformação, preservando a fidelidade original do payload.

CAPíTULO 5

Arquitetura Proposta para o Middleware

O sistema proposto atua como um proxy reverso de privacidade, implementado em Python, colocado entre os clientes e os serviços de backend. Os clientes deixam de comunicar diretamente com a API original: cada pedido é recebido pelo middleware, que valida a credencial, determina o perfil, reencaminha o pedido ao backend e transforma a resposta segundo a política associada a esse perfil antes de a devolver. O backend não necessita de ser alterado, o que permite aplicar a abordagem a serviços já existentes. A Figura 5.1 apresenta a visão geral da arquitetura.

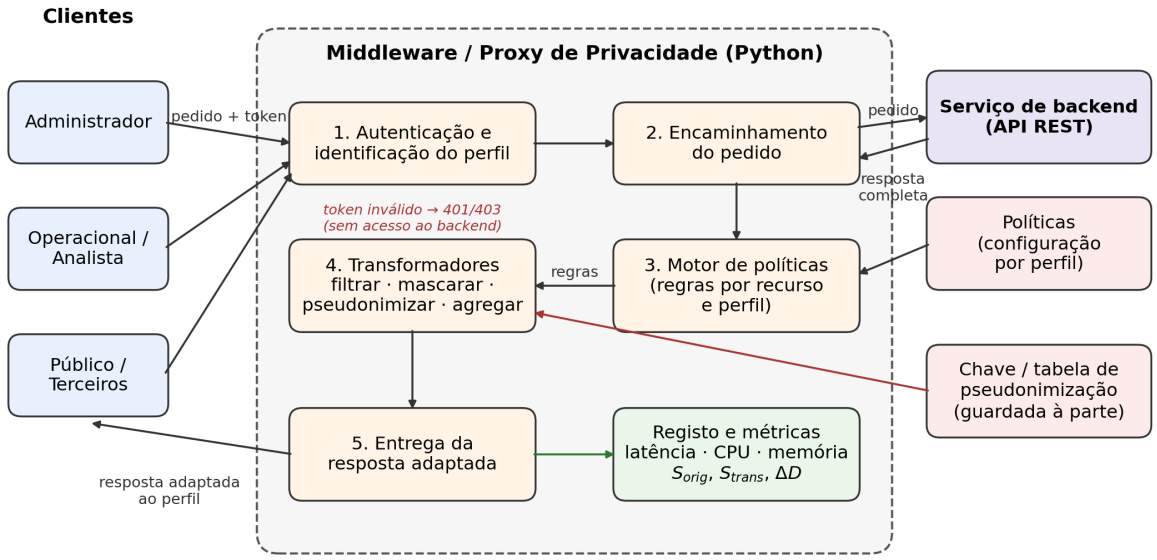


FIGURA 5.1. Arquitetura proposta do middleware adaptativo de privacidade e fluxo de um pedido.

5.1. Componentes

A arquitetura organiza-se em componentes com responsabilidades separadas, de modo a que as políticas possam ser alteradas sem modificar o código de transformação:

- **Autenticação e identificação do perfil:** valida a credencial apresentada pelo cliente (por exemplo, um token assinado) e extrai o perfil a partir dela. O perfil nunca é aceite como um parâmetro livre do pedido. Pedidos sem credencial válida são rejeitados (HTTP 401/403) sem que o backend seja contactado.
- **Encaminhamento:** reencaminha o pedido autorizado para o serviço de backend e recebe a resposta completa, que nunca é devolvida diretamente ao cliente.

- **Motor de políticas:** carrega, a partir de um ficheiro de configuração, as regras definidas por recurso e por perfil, indicando para cada campo a ação a aplicar. Campos não previstos na política são omitidos por defeito, seguindo o princípio do menor privilégio e evitando que atributos novos do backend sejam expostos implicitamente. Além do perfil, o motor pode considerar o nível de risco do contexto do pedido, formalizado no Capítulo 4: quando o risco ultrapassa um limiar, é aplicada uma variante mais restritiva da política, mantendo a utilidade acima do mínimo exigido pelo perfil.
- **Transformadores:** aplicam as ações sobre o payload JSON. As ações previstas são *manter*, *omitir*, *mascarar* (ocultação parcial do valor), *pseudonimizar* (substituição por um identificador derivado com uma chave secreta, por exemplo HMAC-SHA256) e *agregar* (substituição de registos individuais por contagens, médias ou intervalos).
- **Entrega da resposta:** serializa o resultado e devolve-o ao cliente, com cabeçalhos e mensagens de erro que não revelem detalhes internos do backend.
- **Registo e métricas:** regista, sem conteúdo pessoal, o perfil, o recurso, a latência e os tamanhos S_{orig} e S_{trans}, permitindo calcular ΔD (equação 4.2) e o consumo de recursos na avaliação experimental.

A chave de pseudonimização é mantida separadamente da configuração e dos registos, em linha com a definição de pseudonimização do RGPD discutida no Capítulo 2: sem acesso a essa informação adicional, os pseudónimos não permitem, por si só, atribuir os dados a uma pessoa.

5.2. Fluxo de Processamento de um Pedido

O processamento de um pedido segue as etapas numeradas na Figura 5.1:

(1) O cliente envia o pedido HTTP com a sua credencial; o middleware valida-a e determina o perfil. Se a validação falhar, o pedido termina com erro.
(2) O pedido é reencaminhado para o backend, que devolve a resposta completa.
(3) O motor de políticas seleciona as regras correspondentes ao par (recurso, perfil).
(4) Os transformadores aplicam as ações campo a campo ou, no caso da agregação, sobre o conjunto de registos.
(5) A resposta adaptada é devolvida ao cliente e as métricas do pedido são registadas.

5.3. Perfis de Acesso e Políticas de Transformação

O middleware processa as respostas segundo três perfis principais:

- **Perfil Administrador:** recebe os atributos necessários às suas funções, sem transformação dos campos autorizados.
- **Perfil Operacional / Analista:** recebe registos individuais, mas com os identificadores diretos pseudonimizados e os atributos confidenciais mascarados ou omitidos, preservando a utilidade para análise.
- **Perfil Público / Terceiros:** recebe apenas dados agregados e métricas consolidadas, sem registos individuais, minimizando o payload enviado.

A Tabela 5.1 ilustra uma política para um recurso hipotético de clientes, com o resultado esperado para cada perfil.

TABELA 5.1. Exemplo de política de transformação por perfil para um registo de cliente

Campo	**Administrador**	**Operacional / Analista**	**Público / Terceiros**
`id`	Manter	Pseudonimizar (`a91f...`)	Omitir
`nome`	Manter	Omitir	Omitir
`email`	Manter	Mascarar (`j***@mail.pt`)	Omitir
`nif`	Manter	Mascarar (`*****6789`)	Omitir
`data_nasc`	Manter	Generalizar (ano)	Agregar (faixa etária)
`distrito`	Manter	Manter	Agregar (contagem)
`saldo`	Manter	Manter	Agregar (média)

Para o perfil Público, a resposta deixa de ser uma lista de registos e passa a ser um resumo (por exemplo, número de clientes por distrito e saldo médio), o que torna S_{trans} muito inferior a S_{orig}. A agregação sobre grupos muito pequenos pode, no entanto, permitir inferências sobre indivíduos; por isso, a política deve prever um tamanho mínimo de grupo abaixo do qual os valores não são divulgados.

5.4. Considerações de Segurança

Sendo um ponto obrigatório de passagem entre clientes e backend, o middleware é também um alvo e um potencial ponto único de falha. A conceção deve, por isso, contemplar: comunicações protegidas por TLS entre todos os componentes; o backend acessível apenas a partir do middleware, para que não possa ser contornado; validação da assinatura e da validade dos tokens; gestão das chaves fora do código-fonte; registos sem dados pessoais; e um comportamento seguro em caso de erro, em que uma falha na política ou na transformação resulta em recusa da resposta e não na devolução do payload original.

5.5. Tecnologias e Plano de Avaliação

O protótipo será desenvolvido em Python com FastAPI (ou Flask), recorrendo a um cliente HTTP para o encaminhamento e a um backend de teste com dados sintéticos, evitando a utilização de dados pessoais reais. A avaliação compara dois cenários, acesso direto ao backend e acesso através do middleware, para cada um dos perfis, medindo:

- **Correção funcional:** cada perfil recebe exatamente os campos e as transformações previstos na política, e pedidos não autorizados são rejeitados;
- **Latência:** tempo de resposta médio e percentis (p50, p95) com e sem middleware;
- **Recursos:** consumo de CPU e memória do processo do middleware sob carga;

- **Payload e informação:** S_{orig}, S_{trans} e ΔD por perfil, e a entropia $H(X)$ dos atributos expostos (equação 4.1).

CAPíTULO 6

Conclusões e Trabalhos Futuros

Este relatório apresentou a fundamentação teórica de um middleware adaptativo de privacidade para APIs REST, que adapta o conteúdo das respostas ao perfil do consumidor em vez de se limitar a permitir ou negar o acesso. Foram enquadrados os requisitos relevantes do RGPD, em particular a minimização dos dados, a proteção de dados desde a conceção e a pseudonimização, e da Diretiva NIS2, no que respeita à gestão de riscos e à resiliência dos sistemas. A análise do estado da arte permitiu posicionar a proposta face ao controlo de acesso tradicional e aos modelos PRIPRO/PRIADA e PADRES, dos quais se retiram, respetivamente, a gestão dinâmica de perfis e a adaptação contextual, bem como o enquadramento de avaliação regulamentar e de segurança.

A revisão de literatura permitiu ainda identificar outras abordagens relevantes à minimização de dados, nomeadamente o Janus e o minTAP. Enquanto o Janus aplica mecanismos configuráveis de redução de informação ao nível dos atributos disponibilizados por APIs GraphQL, o minTAP procura limitar o acesso excessivo a dados e serviços em plataformas de automação. Estes trabalhos demonstram a viabilidade da aplicação de políticas de minimização diretamente às interfaces de acesso aos dados, constituindo uma referência para a abordagem proposta. A principal diferenciação do middleware consiste em reunir a gestão de perfis, a adaptação contextual e a transformação das respostas numa camada intermédia direcionada a APIs HTTP/REST.

No plano matemático, foram formalizadas duas métricas complementares. A Entropia de Shannon $H(X)$ (equação 4.1) permite quantificar a informação contida nos atributos revelados antes e depois da intervenção do middleware, servindo também de critério para decidir quando aplicar pseudonimização, anonimização ou supressão. A taxa de redução do payload ΔD (equação 4.2) quantifica a diminuição dos dados transmitidos e não é um valor fixo: depende do perfil do recetor, da criticidade dos dados e do nível de risco do contexto. As duas métricas foram integradas numa função de decisão adaptativa, formulada como um problema de otimização que maximiza o ganho de privacidade $\mathcal{P}(\Delta D, H(X))$ sujeito a uma utilidade mínima $U \geq U_{min}$. Quando o risco do contexto $R(t)$ ultrapassa um patamar crítico, o middleware intensifica as transformações; em ambiente confiável, preserva maior fidelidade do payload.

Por fim, foi proposta uma arquitetura modular que concretiza esta formulação, com separação entre autenticação, motor de políticas e transformadores, políticas explícitas por perfil, omissão por defeito dos campos não previstos e recolha das métricas necessárias para calcular $H(X)$ e ΔD em cada pedido. As transformações previstas incluem a seleção de campos, a mascaragem ou pseudonimização de atributos e a agregação de informação,

permitindo aplicar diferentes níveis de proteção aos mesmos recursos em função do perfil e do contexto do pedido.

A proposta tem limitações que importa reconhecer. As métricas caracterizam o comportamento do protótipo, mas não demonstram, por si só, conformidade regulatória; a mascaragem e a pseudonimização não equivalem a anonimização; e a introdução de uma camada intermédia acrescenta latência e um novo componente que tem de ser protegido. Além disso, a função de risco $R(t)$, a medida de utilidade U e o limiar U_{min} foram definidos a nível conceptual, e a sua concretização depende do cenário de aplicação. A validade da abordagem terá, por isso, de ser avaliada experimentalmente.

Como trabalho futuro, no âmbito da Parte 2 do projeto, será implementado o protótipo em Python com FastAPI/Flask, juntamente com um backend de teste com dados sintéticos e políticas para os três perfis. Serão desenvolvidos testes funcionais e scripts de benchmarking para comparar o acesso com e sem middleware em termos de latência, consumo de CPU e memória, ΔD e entropia dos dados expostos. Esta avaliação permitirá analisar não só a eficácia das transformações aplicadas, mas também o compromisso entre a redução da informação transmitida, a preservação da utilidade funcional das respostas e o custo computacional introduzido. Como extensões possíveis, identificam-se a concretização da função de risco do contexto e da medida de utilidade a partir de atributos observáveis (por exemplo, finalidade declarada, horário ou origem do pedido), a aplicação de técnicas como o k-anonimato ou a privacidade diferencial aos dados agregados, e a cache de respostas transformadas para reduzir o custo introduzido pelo middleware.

Referências Bibliográficas

[1] Jefferson Cesconetto, Luis Arthur Silva, Francisco Bortoluzzi, Marcelo Navarro-Cáceres, Carlos Alberto Zeferino, and Villians R. Q. Leithardt. Pripro: Privacy profiles – user profiling management for smart environments. *Electronics*, 9(9):1519, 2020.

[2] Fábio Pereira, Pedro Crocker, and Villians R. Q. Leithardt. Padres: Tool for privacy, data regulation and security. *SoftwareX*, 17:100895, 2022.

[3] European Parliament and Council of the European Union. Regulation (eu) 2016/679 of the european parliament and of the council of 27 april 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data. Official Journal of the European Union, L 119, 4 May 2016, pp. 1–88, 2016.

[4] European Parliament and Council of the European Union. Directive (eu) 2022/2555 of the european parliament and of the council of 14 december 2022 on measures for a high common level of cybersecurity across the union (nis 2 directive). Official Journal of the European Union, L 333, 27 December 2022, pp. 80–152, 2022.

[5] Valderi Reis Quietinho Leithardt. *UbiPri – Middleware for Privacy Control and Management in Ubiquitous Environments*. PhD thesis, Federal University of Rio Grande do Sul, 2015.

[6] Iago Sestrem Ochôa, Luis Augusto Silva, Gabriel de Mello, Bruno Alves da Silva, Juan Francisco de Paz, Gabriel Villarrubia González, Nuno M. Garcia, and Valderi Reis Quietinho Leithardt. PRICHAIN: A partially decentralized implementation of UbiPri middleware using blockchain. *Sensors*, 19(20):4483, 2019.

[7] Hugo Lopes, Ivan Miguel Pires, Hector Sánchez San Blas, Raúl García-Ovejero, and Valderi Leithardt. PriADA: Management and adaptation of information based on data privacy in public environments. *Computers*, 9(4):77, 2020.

[8] Frank Pallas, David Hartmann, Paul Heinrich, Josefine Kipke, and Elias Grünewald. Configurable per-query data minimization for privacy-compliant web apis. In *Web Engineering: 22nd International Conference, ICWE 2022*, pages 325–340. Springer, 2022.

[9] Yunang Chen, Mohannad Alhanahnah, Andrei Sabelfeld, Rahul Chatterjee, and Earlence Fernandes. Practical data access minimization in trigger-action platforms. In *31st USENIX Security Symposium*, pages 2929–2945. USENIX Association, 2022.

[10] Claude E. Shannon. A mathematical theory of communication. *Bell System Technical Journal*, 27(3):379–423, 1948.